

到有法可依，有法必依；建立国家信息安全组织管理体系，加强国家信息安全机构及职能；建立高效能、职责分工明确的行政管理和业务组织体系；建立信息系统安全标准和评估体系；建立国家信息安全技术保障体系，使用科学技术实施安全的防护保障。

9.2 数据安全与保密

为用户提供安全、可靠的保密通信，是信息系统安全最为重要的内容，尽管系统安全不仅仅局限于保密性，但不能提供保密性的系统肯定是不安全的。系统的保密性机制除了为用户提供保密通信以外，也是其他安全机制的基础。例如，访问控制中登录口令的设计、安全通信协议的设计和数字签名的设计等，都离不开密码机制。

9.2.1 数据加密技术

加密是指对数据进行编码变换，使其看起来毫无含义，但同时却仍可以保持其可恢复的形式过程。在这个过程中，被变换的数据称为明文，它可以是一段有意义的文字或者数据，变换后的数据称为密文。加密机制有助于保护信息的机密性和完整性，有助于识别信息的来源，它是最广泛使用的安全机制。

传统加密算法主要包括代换加密和置换加密两种。代换加密的方法是，首先构造一个或多个密文字母表，然后用密文字母表中的字母或字母组来代替明文字母或字母组，各字母或字母组的相对位置不变，但其本身改变了；置换加密将明文中的字母重新排列，字母本身不变，但其位置改变了。传统加密算法具有设计简单的特点，曾经得到大量使用。但它们的一个主要弱点是，算法和密钥密切相关。攻击者可以利用字母的统计和语言学知识，破译密文相对容易，尤其是在计算机技术高度发展的今天，可以充分利用计算机进行密文分析。

从20世纪60年代开始，随着电子技术、计算机技术的迅速发展，以及结构代数、可计算性和计算复杂性理论等学科的研究，密码学又进入了一个新的发展时期。在20世纪70年代后期，对称加密算法和非对称加密算法的出现，成为了现代密码学发展史中的两个重要里程碑。

1. 对称加密算法

对称加密算法也称为私钥加密算法，是指加密密钥和解密密钥相同，或者虽然不同，但从其中的任意一个可以很容易地推导出另一个。其优点是具有很高的保密强度，但密钥的传输需要经过安全可靠的途径。对称加密算法有两种基本类型，分别是分组密码和序列密码。分组密码是在明文分组和密文分组上进行运算，序列密码是对明文和密文数据流按位或字节进行运算。

常见的对称加密算法包括瑞士的国际数据加密算法（International Data Encryption Algorithm, IDEA）和美国的数据加密标准（Data Encryption Standard, DES）。

2. 非对称加密算法

非对称加密算法也称为公钥加密算法，是指加密密钥和解密密钥完全不同，其中一个为公钥，另一个为私钥，并且不可能从任何一个推导出另一个。它的优点在于可以适应开放性的使

用环境，可以实现数字签名与验证。

最常见的非对称加密算法是 RSA，它的密钥长度为 512 位，保密性取决于数学上将一个数分解为两个素数的问题的难度，根据已有的数学方法，其计算量极大，破解很难。但是加密/解密时要进行大指数模运算，因此加密/解密速度很慢，主要用在数字签名中。

9.2.2 认证技术

信息的完整性一方面是指信息在利用、传输、存储等过程中不被删除、修改、伪造、乱序、重放和插入等，另一方面是指信息处理方法的正确性。不适当的操作（例如，误删除文件等）有可能造成重要文件的丢失。完整性和保密性不同，保密性要求信息不被泄露给未授权的人，而完整性则要求信息不受到各种原因的破坏。

认证（authentication）又称为鉴别或确认，它是证实某事物是否名副其实或是否有效的过程。认证和加密的区别在于，加密用于确保数据的保密性，阻止非法者的被动攻击，例如，截取和窃听等；而认证用于确保数据发送者和接收者的真实性和消息的完整性，阻止非法者的主动攻击，例如，冒充、篡改和重放等。认证往往是许多应用系统中安全保护的第一道防线，因而极为重要。

1. 数字签名

数字签名是附加在数据单元上的一些数据，或是对数据单元所作的密码变换。这种数据或变换允许数据单元的接收者用以确认数据单元的来源和数据单元的完整性并保护数据，防止被人（例如，接收者）进行伪造。基于对称加密算法和非对称加密算法都可以获得数字签名，但目前主要是使用基于非对称加密算法的数字签名，包括普通数字签名和特殊数字签名。普通数字签名算法有 RSA、ElGamal、Fiat-Shamir、Des/DSA、椭圆曲线数字签名算法和有限自动机数字签名算法等；特殊数字签名算法有盲签名、代理签名、群签名、不可否认签名、公平盲签名、门限签名和具有消息恢复功能的签名等，它与具体应用场景密切相关。显然，数字签名的应用涉及法律问题，美国联邦政府基于有限域上的离散对数问题制定了自己的数字签名标准（Digital Signature Standard, DSS）。

数字签名的主要功能是保证信息传输的完整性、发送者的身份认证、防止交易中的抵赖发生。因此，不管使用哪种算法，数字签名必须保证以下三点：

- （1）接收者能够核实发送者对数据的签名，这个过程称为鉴别。
- （2）发送者事后不能抵赖对数据的签名，这称为不可否认。
- （3）接收者不能伪造对数据的签名，这称为数据的完整性。

2. 数字签名算法

（1）杂凑算法。杂凑算法是主要的数字签名算法，它是利用散列（Hash）函数（哈希函数、杂凑函数）进行数据的加密。单向 Hash 函数提供了这样一种计算过程：输入一个长度不固定的字符串，返回一串定长的字符串，这个返回的字符串称为消息摘要（Message Digest, MD），也称为 Hash 值或散列值。Hash 函数主要可以解决以下两个问题，首先，在某一特定的时间内，无法查找经 Hash 操作后生成特定 Hash 值的原消息；其次，无法查找两个经 Hash 操作后生成相

同 Hash 值的不同消息。这样，在数字签名中就可以解决验证签名、用户身份验证和不可抵赖性的问题。

(2) 消息摘要算法。消息摘要算法 (Message Digest algorithm 5, MD5) 用于确保信息传输完整一致，经 MD2、MD3 和 MD4 发展而来。它的作用是把大容量信息在用数字签名软件签署私人密钥前“压缩”成一种保密的格式，即将一个任意长度的字符串变换成一个定长的大数)。不管是 MD2、MD4 还是 MD5，它们都需要获得一个随机长度的信息并产生一个 128 位的消息摘要。MD5 以 512 位分组来处理输入的信息，且每个分组又被划分为 16 个 32 位子分组，经过一系列的处理后，算法的输出由 4 个 32 位分组组成，将这 4 个 32 位分组级联后，将生成一个 128 位的散列值。

(3) 安全散列算法。安全散列算法 (Secure Hash Algorithm, SHA) 能计算出一个数字信息所对应的长度固定的字符串 (消息摘要)，它对长度不超过 264 位的消息产生 160 位的消息摘要。这些算法之所以被称作“安全”，是基于以下两点：第一，由消息摘要反推原输入信息，从计算理论上来说是很困难的；第二，想要找到两组不同的信息对应到相同的消息摘要，从计算理论上来说也是很困难的，因为任何对输入信息的变动，都有很高的概率导致其产生的消息摘要不同。

SHA 家族的 5 个算法分别是 SHA-1、SHA-224、SHA-256、SHA-384 和 SHA-512，由美国国家安全设计，并由美国国家标准与技术研究院发布，是美国的政府标准。后四者有时统称为 SHA-2。SHA-1 在许多安全协议中广为使用，包括传输层安全协议 (Transport Layer Security, TLS) 和安全套接层 (Secure Sockets Layer, SSL)、优良保密协议 (Pretty Good Privacy, PGP)、安全外壳 (Secure Shell, SSH)、安全/多功能 Internet 邮件扩展 (Secure/Multipurpose Internet Mail Extensions, S/MIME) 和互联网安全协议 (Internet Protocol Security, IPSec) 等，SHA-1 曾被视为 MD5 的后继者。

3. 数字证书

数字证书又称为数字标识，是由认证中心 (Certificate Authority, CA) 签发的对用户的公钥的认证。数字证书的内容应包括 CA 的信息、用户信息、用户公钥、CA 签发时间和有效期等。目前，国际上对证书的格式和认证方法遵从 X.509 体系标准。

在 X.509 格式中，数字证书通常包括版本号、序列号 (CA 下发的每个证书的序列号都是唯一的)、签名算法标识符、发行者名称、有效期、主体名称、主体的公钥信息、发行者唯一识别符、主体唯一识别符、扩充域、发行者签名 (就是 CA 用自己的私钥对上述数据进行数字签名的结果，也可以理解为 CA 中心对用户证书的签名) 等信息。

任何一个用户只要得到 CA 的公钥，就可以得到 CA 为该用户签署的数字证书。因为证书是不可伪造的，因此，对于存放证书的目录无须施加特别的保护。如果两个用户使用的是不同 CA 发放的证书，则无法直接使用证书；但如果两个 CA 之间已经安全地交换了公开密钥，则可以使用证书链来完成通信。当数字证书过了有效期、用户私钥已泄露、用户放弃使用原 CA 的服务、CA 私钥泄露等，都需要吊销证书，这时，CA 会维护一个证书撤销列表 (Certificate Revocation List, CRL)，供用户查询。